Nhịp IAM — Quản lý danh tính và giám sát truy cập

1	Lê Minh Nhật · Nguyễn Minh Tuấn
2	Web A: Nhịp Workspace · Web B: Nhịp Security
3	Keycloak · MFA · LDAP · JCL · Audit · Python Detection
4	Bản thảo kỹ thuật: mã tuần 5–10 chưa được nghiệm thu

Bài toán và phạm vi

1	Tập trung danh tính, quyền, phiên và dấu vết truy cập của hai ứng dụng
2	Nhân viên, quản lý, quản trị viên và kiểm toán viên có phạm vi khác nhau
3	Lab HTTPS trên máy chủ và máy khách cùng LAN/VPN riêng
4	Mô hình theo định hướng Zero Trust; chưa phải nền tảng doanh nghiệp đầy đủ

Kiến trúc và ranh giới tin cậy

1	Trình duyệt → HTTPS gateway → React / Express / Keycloak
2	Keycloak → PostgreSQL danh tính; federation → OpenLDAP LDAPS
3	Express → SQLite nghiệp vụ/hold/outbox → Audit Service → PostgreSQL riêng
4	Python worker phân tích audit; trình duyệt không giữ service secret

Xác thực và MFA

1	OIDC Authorization Code + PKCE S256; kiểm tra chữ ký, issuer, audience và client
2	MFA và required actions do chính sách quản trị điều khiển
3	Token hợp lệ vẫn cần account/role/scope/session và trạng thái local hợp lệ
4	Recovery MFA có xác thực lại gần thời điểm thao tác và lịch sử xử lý

SSO và phân quyền

1	SSO theo hồ sơ trình duyệt; hai máy có phiên đăng nhập độc lập
2	Web B chỉ dành cho admin/auditor, token không dùng cho chấm công Web A
3	Kiểm tra vai trò, nhóm và chủ sở hữu ở API, không dựa vào việc ẩn nút
4	Logout/revoke phải được xác nhận hai chiều; cache có giới hạn cần đo

LDAP là nguồn danh tính

1. OpenLDAP LDAPS; Keycloak federation READ_ONLY
2. Nhóm nguồn ánh xạ vai trò; trạng thái/nhóm mâu thuẫn phải fail-closed
3. Web B có danh bạ, ánh xạ và lịch sử đồng bộ
4. Không sửa user LDAP trực tiếp để vượt chính sách nguồn

Join — Change — Leave

1	Yêu cầu → phê duyệt → hold/cutoff → thực hiện → đối chiếu
2	LDAP được ghi bằng CLI operator theo workflow đã duyệt
3	Lỗi giữa bước giữ partial và hold; execute không đồng nghĩa thành công
4	Grant có thời hạn, đúng scope; không tự duyệt và không nâng role nền

Audit tập trung

1. PostgreSQL Audit tách khỏi DB nội bộ Keycloak
2. Outbox SQLite cùng transaction; ACK sau commit, replay cùng event ID
3. Collector user/admin events: checkpoint, trang, retry, backfill và gap
4. Không lưu token, OTP, mật khẩu, request body hay admin representation

Security Monitoring trên Web B

1	ALLOW/DENY theo ngày, top lỗi login và đối chiếu nguồn
2	Lọc thời gian/user/action, phân trang, CSV, request/session correlation
3	Incident có trạng thái, note, actor và version chống ghi đè
4	Health thể hiện backlog/lỗi; retention có preview và xác nhận riêng

Python Detection có giải thích

1	Login failures, DENY liên tiếp, employee thử admin, token đã thu hồi
2	IP mới, ngoài giờ, request spike là tín hiệu cần điều tra
3	Features theo event-time; batch 200, checkpoint/kết quả cùng transaction
4	Normal không đảm bảo an toàn; Anomaly không tự khóa tài khoản

Dữ liệu và phương pháp đánh giá

1	Nhãn từ kịch bản xác nhận độc lập, không lấy nhãn của luật để tự đánh giá
2	Tách train/evaluation theo scenario; kiểm tra trùng và rò rỉ dữ liệu
3	Snapshot dataset, SHA-256, config version và TP/FP/TN/FN
4	Precision/Recall/F1/FPR, latency và processing time được phân biệt

Kết quả thực nghiệm lab 08/11/2026

1	Backend 130/130; tiện ích frontend 8/8; Python 7/7
2	SSO 29/29; UI 42/42; nghiệp vụ 24/24; màn hình mới 19/19
3	JCL local 24/24 và LDAP 23/23; Audit/Detection 100/100
4	27 mẫu mô phỏng: TP7/TN20/FP0/FN0; không suy rộng ra dữ liệu doanh nghiệp

Bàn giao và khôi phục

1	Runner/Compose, source ZIP có manifest, tài liệu vận hành và sơ đồ
2	Backup Keycloak, LDAP, SQLite, Audit và cấu hình private
3	Restore Audit vào project mới cô lập; không ghi đè database đang chạy
4	Snapshot phối hợp cần dừng writer; ZIP source không thay backup dữ liệu

Kịch bản demo sau nghiệm thu

1	LDAP login + MFA → SSO với role hợp lệ → API trái quyền trả 403
2	Change role/group → revoke phiên hoặc Leave → kiểm tra token cũ
3	Audit PostgreSQL → Python Detection → giải thích FP/FN và metrics
4	Có ảnh/video thao tác thật tại evidence/release; không ghi mật khẩu/QR/secret OTP

Giới hạn và hướng phát triển

1	Lab một backend; chưa chứng minh HA, hiệu năng hoặc không mất log end-to-end
2	Late events, cache, backlog và chất lượng nhãn ảnh hưởng kết quả
3	Chưa triển khai ML khi thiếu dataset độc lập; không thêm công nghệ sát bảo vệ
4	Còn xác nhận máy vật lý thứ hai, phục hồi phối hợp mọi kho và diễn tập bảo vệ